

SECURITY ASSESSMENT REPORT

Metasploitable 2 Virtual Lab

Prepared by

Kinan Alghamdi (GitHub: kinan213)

Date

07 October 2026

CONFIDENTIAL · Personal Training-Lab Assessment

EXECUTIVE SUMMARY

This personal training-lab project, carried out by Kinan Alghamdi (GitHub: kinan213), assessed a Metasploitable 2 host in an isolated virtual lab and found 21 vulnerabilities, 11 of them Critical. The host runs an end-of-life operating system and exposes a large number of outdated, insecure network services, several of which allow an attacker to gain full control of the machine with no credentials.

The single most important takeaway is that the host should not be connected to any production or internet-facing network in its current state. The findings point to a systemic absence of patch management and secure configuration rather than any single isolated flaw. The practical response is to rebuild the host on a supported operating system and disable every service that is not strictly required.

This report documents what was assessed, how, what was found, and what should be done about it.

SCOPE AND OBJECTIVES

The assessment covered a single host at 192.168.56.101, a Metasploitable 2 instance — a deliberately vulnerable training system — running inside a private virtual lab built by Kinan Alghamdi for this project. All testing was conducted from a separate assessor host at 192.168.56.102 on an isolated host-only network with no route to the internet or any other system.

The following were explicitly out of scope and were not tested: the lab gateway (192.168.56.1), the virtual DHCP service (192.168.56.100), the assessor host itself, and any system outside the 192.168.56.0/24 lab network. Defining and respecting scope is a core discipline of a controlled assessment, and the out-of-scope hosts were identified during discovery and deliberately left untouched.

The objective was to identify the security weaknesses present on the target, rate each by risk, map the findings to recognised control frameworks, and produce prioritised remediation guidance.

METHODOLOGY

The lab consisted of two virtual machines on a VirtualBox host-only network. The target ran Metasploitable 2, an intentionally vulnerable Linux image. The assessor host ran Kali Linux, configured with two adapters: one NAT adapter for tool updates and one host-only adapter for the isolated lab. Isolation was verified by confirming the target could not reach the internet.

Testing proceeded in three stages:

1. Host discovery mapped the lab network and identified live hosts, so that scanning could be confined to the single in-scope target.
2. Service and version detection scanned all 65,535 TCP ports to enumerate open services, their software versions, and the host operating system.
3. Vulnerability detection ran Nmap's NSE vulnerability scripts against the target to confirm specific known vulnerabilities and their CVE identifiers.

Each finding was recorded in a risk register and rated using a standard likelihood × impact model. Likelihood and impact were each scored from 1 to 5, and their product placed the finding in one of four bands: Low (1–4), Medium (5–9), High (10–15), or Critical (16–25). Every finding was mapped to the relevant control in both ISO/IEC 27001 and the NIST Cybersecurity Framework.

KEY FINDINGS

The target exposed 23 open services. The most serious findings fall into five themes.

Backdoors and remote code execution. The host exposes a bind shell on port 1524 that grants an unauthenticated root shell to anyone who connects. It also runs software versions with documented backdoors: vsftpd 2.3.4 (CVE-2011-2523) and UnrealIRCd (CVE-2010-2075). The Java RMI registry on port 1099 permits remote code execution through its default configuration, confirmed by the scan. Each of these allows full compromise of the host.

Cleartext protocols. Telnet (port 23), the legacy r-services rlogin, rsh and rexec (ports 512–514), and FTP (ports 21 and 2121) all transmit credentials and data without encryption. Any party able to observe network traffic can capture administrative logins.

Exposed network services. MySQL (3306), PostgreSQL (5432), Samba file sharing (139 and 445), and NFS (2049) are all reachable over the network. These are common paths for unauthorised data access and lateral movement, particularly where default or weak credentials are in use.

Outdated transport cryptography. The scan confirmed several TLS weaknesses: POODLE (CVE-2014-3566), Logjam and export-grade Diffie-Hellman (CVE-2015-4000), and OpenSSL CCS Injection (CVE-2014-0224). These enable interception or tampering of traffic that is supposed to be encrypted.

End-of-life operating system. The host runs a Linux 2.6 kernel, which is long past end of life and no longer receives security patches. This is the root cause that ties the other findings together: without a supported platform and a patching process, vulnerabilities accumulate indefinitely.

The web server additionally exposed diagnostic and administrative pages (phpinfo, phpMyAdmin, directory listings) and had the HTTP TRACE method enabled, both of which aid an attacker in reconnaissance.

RISK SUMMARY

The 21 findings break down as follows.

Risk Level	Count
Critical	11
High	4
Medium	5
Low	1
Total	21

More than half of all findings are Critical. On a live system this would constitute an emergency: multiple independent paths to full host compromise, any one of which an attacker could use. The concentration of Critical findings on a single host, combined with an unsupported operating system, means the host cannot be meaningfully secured through incremental fixes and should be rebuilt.

RECOMMENDATIONS

Remediation is grouped by priority.

Do first — contain the critical exposure.

4. Isolate the host from any untrusted network until it is remediated.
5. Remove the bind-shell backdoor on port 1524 and rebuild the host from a trusted image.
6. Replace or upgrade the services with known backdoors (vsftpd, UnrealIRCd) and secure the Java RMI service.

Do next — reduce the attack surface.

7. Disable all cleartext remote-access protocols (Telnet, rlogin, rsh, rexec) and require SSH instead.
8. Restrict database and file-sharing services (MySQL, PostgreSQL, Samba, NFS) to trusted hosts, and enforce strong authentication.
9. Disable weak TLS protocols and ciphers, and patch OpenSSL to address POODLE, Logjam, and CCS Injection.

Ongoing — address the root cause.

10. Migrate the host to a supported operating system and establish a patch-management process so updates are applied regularly.
11. Define a secure-configuration baseline that disables unnecessary services by default.
12. Remove diagnostic and administrative web pages from production and disable the HTTP TRACE method.

The first two groups treat the immediate symptoms. The third group is what prevents the same situation from recurring, and is where the lasting value of the assessment lies.

LIMITATIONS AND NOTES

Several findings warrant an honest qualification.

The two software backdoors (vsftpd 2.3.4 and UnrealIRCd) are rated on the basis of the version numbers reported by the service scan, which are known to be vulnerable. The vulnerability scripts did not independently re-confirm active exploitation of these two. They remain high-confidence findings, but the distinction between version-inferred and tool-confirmed is noted in the risk register.

Not every check returned a positive result, and the negatives are recorded too. The SMB vulnerability checks for MS10-054 and MS10-061 both returned not vulnerable. Recording what was tested and found safe is as much a part of an honest assessment as recording what was found vulnerable.

An authenticated vulnerability scan using Greenbone/OpenVAS was attempted to supplement these results with CVSS severity scores. The scanner's vulnerability feed did not finish importing within the assessment window, so those results are not included. The findings in this report rest on Nmap service detection and Nmap NSE vulnerability scripts, which together provide confirmed open services, software versions, and CVE-referenced vulnerabilities.

Finally, the likelihood and impact scores reflect this isolated lab context. Several of the transport-cryptography findings would be rated higher on a production system that carries real user traffic, and lower in a closed environment. The scores are a reasoned judgement, not an absolute, and would be revisited for a different deployment.

CONCLUSION

The assessment found a host that is comprehensively insecure, with 11 Critical findings driven by an unsupported operating system and a wide surface of outdated services. The appropriate response is to rebuild on a supported platform, disable unnecessary services, and put a patching and secure-configuration process in place.

Beyond the technical result, the exercise demonstrates the full governance, risk, and compliance workflow: scoping an assessment, gathering evidence, translating raw technical findings into scored risks, mapping those risks to ISO/IEC 27001 and NIST controls, and communicating prioritised recommendations to the people who must act on them. That translation — from a scanner's output to a decision a business can make — is the purpose of the work.